

Guía paso a paso para explorar solicitudes HTTP con Burp Suite

Paso 1 abre Burp Suite Community Edition y asegúrate de que la herramienta esté operativa. No necesitas iniciar un proyecto específico, solo confirma que la pestaña Proxy está activa.

Paso 2 abre tu navegador web, preferentemente Firefox, y configura el proxy para redirigir el tráfico a la dirección local 127.0.0.1 en el puerto 8080. Este ajuste se realiza en las opciones de configuración de red del navegador, desactivando la detección automática y especificando el proxy manual.

Paso 3 en Burp Suite, asegúrate de que la opción "Intercept is on" esté habilitada en la pestaña Proxy > Intercept. Esto te permitirá capturar y observar las solicitudes generadas por el navegador en tiempo real.

Paso 4 abre una nueva pestaña en tu navegador y accede al sitio de prueba utilizando la URL <http://testphp.vulnweb.com>. Este sitio está diseñado para realizar prácticas de seguridad y contiene formularios y enlaces vulnerables a manipulación.

Paso 5 realiza una acción sencilla en el sitio como hacer clic en el enlace "Search" o enviar un formulario de búsqueda ingresando una palabra cualquiera como "laptop". Esta acción generará una solicitud HTTP desde el navegador hacia el servidor.

Paso 6 vuelve a Burp Suite y observa que la solicitud generada fue interceptada. Deberías ver en la pestaña Intercept una línea como `GET /artsearch.php?artname=laptop&submit=Search HTTP/1.1`, acompañada de encabezados como `Host`, `User-Agent`, y otros.

Paso 7 detalla los elementos clave de la solicitud capturada. El método HTTP debería ser `GET`, la URL incluirá parámetros como `artname` y `submit`. Los encabezados relevantes serán `Host`, que indica el dominio; `User-Agent`, que refleja el navegador y sistema operativo del cliente; y otros como `Accept`, `Accept-Encoding`, `Connection`.

Paso 8 analiza los parámetros enviados. En una solicitud GET, estos aparecerán directamente en la URL como cadena de consulta. En este caso, se espera algo como `/artsearch.php?artname=laptop&submit=Search`, donde `artname` contiene el valor ingresado en el formulario y `submit` representa el botón de acción.

Paso 9 determina posibles vectores de ataque observando los parámetros reflejados. Si `artname` se utiliza directamente en el HTML de respuesta sin validación, podría ser vulnerable a inyección de scripts o consultas SQL. Se espera que identifiques esta posibilidad como parte del análisis.

Paso 10 documenta el análisis completo de la solicitud. Incluye una captura de pantalla de la solicitud interceptada desde la pestaña Proxy, una tabla o descripción con los campos clave de la solicitud (método, URL, headers, parámetros) y una reflexión técnica sobre qué parte podría representar un riesgo si no se valida correctamente.

Paso 11 realiza pruebas adicionales utilizando el módulo Repeater de Burp Suite. Envía nuevamente la misma solicitud pero alterando el parámetro `artname` para incluir vectores de prueba como `artname=' OR '1'='1` para evaluar inyecciones SQL o `artname=<script>alert('XSS')</script>` para validar vulnerabilidades XSS reflejadas.

Paso 12 observa la respuesta en la pestaña Response del Repeater. Si el payload se refleja sin codificación o es ejecutado por el navegador, esto confirma una posible vulnerabilidad. Se espera ver el script reflejado o el cambio en el comportamiento de la página.

Paso 13 documenta los hallazgos incluyendo capturas de pantalla de las pruebas en Repeater, evidencia del reflejo o ejecución del contenido inyectado, y un análisis técnico que explique por qué el sistema es vulnerable y qué tipo de ataque sería posible en un entorno real.